MediConnect : sécurisation de l'infrastructure réseau d'une plateforme de prise de rendez-vous médicaux

Projet de Sécurité des réseaux – Salim Benayoune

Auteur : Ibrahima Sory DIALLO
Date : octobre 2026
Dépôt du projet : https://github.com/kyro776/mediconnect-network-security

---

Sommaire

1. Contexte et démarche
2. Architecture retenue
3. Plan d'adressage
4. Zones de sécurité et niveaux de confiance
5. VPN utilisés
6. Mécanismes d'authentification
7. Politique de filtrage
8. Règles basées sur l'identité
9. Contrôle applicatif
10. Protection de la DMZ
11. Séparation entre production et démonstration
12. Sécurisation de l'administration
13. Stratégie de journalisation
14. Tests réalisés
15. Limites de la solution
16. Conclusion

Annexe : captures complémentaires

---

1. Contexte et démarche

MediConnect lance une plateforme de prise de rendez-vous médicaux. L'entreprise dispose d'un siège, qui héberge les serveurs et la plateforme publique, et d'un site secondaire, chacun avec son propre accès Internet. Cinq populations utilisent le système d'information : les patients et les médecins depuis Internet, les employés en télétravail, les commerciaux itinérants et les administrateurs.

La solution a été réalisée sous forme de maquette virtualisée sous VMware Workstation : deux pare-feu OPNsense 26.7 et des serveurs Debian 13 sans interface graphique. Les images d'installation ont été vérifiées par leur empreinte SHA-256 avant usage. Le développement applicatif n'étant pas dans le périmètre, un portail simple a été écrit uniquement pour disposer d'un service réaliste à protéger et à tester.

Trois principes ont guidé tous les choix : **tout interdire par défaut**, **n'ouvrir que le strict nécessaire** et **journaliser chaque décision**. Chaque mesure a été testée dans les deux sens : le flux légitime passe, le flux interdit est bloqué.

Ce rapport présente les choix et leur justification ; le détail des configurations est disponible dans le dépôt du projet.

2. Architecture retenue

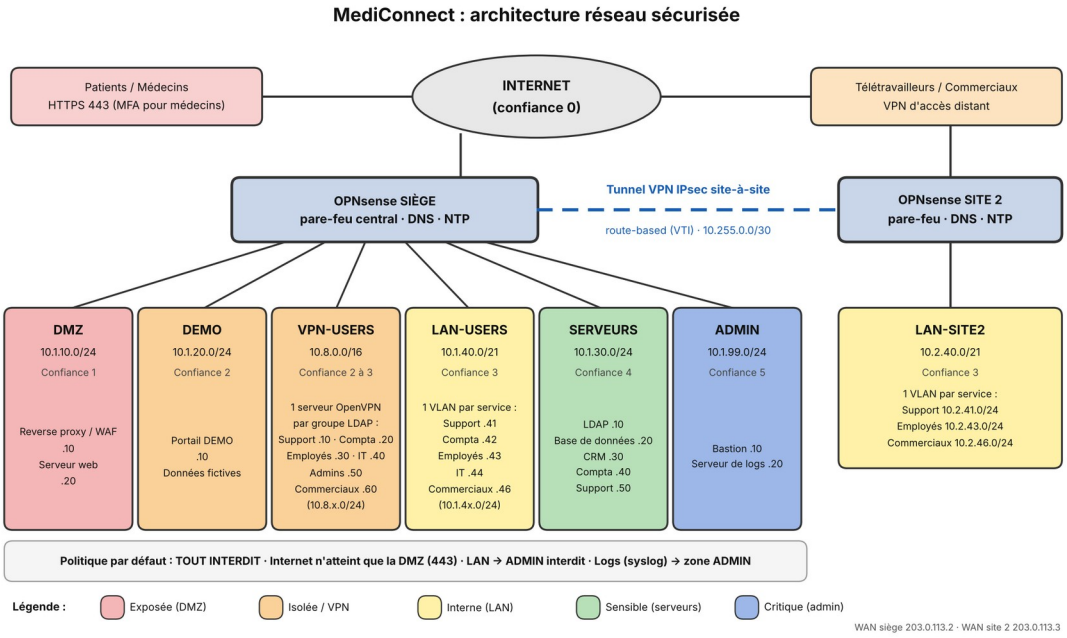


Figure 1 : architecture globale de MediConnect

Décision	Justification
Un pare-feu par site, chacun sur son accès Internet	Imposé par le sujet ; chaque site reste protégé même si l'autre est compromis
Au siège, un pare-feu central avec une interface par zone	Tout flux entre deux zones le traverse : la politique est appliquée et journalisée en un seul point
Sites reliés par un tunnel IPsec	Le trafic entre sites traverse Internet chiffré et authentifié
VPN d'accès distant terminés au siège	Les ressources y sont ; les utilisateurs distants arrivent dans une zone dédiée, filtrée comme les autres
DNS et heure (NTP) fournis par les pare-feu	Pas de serveur supplémentaire ni de flux sortant vers Internet ; chaque zone n'interroge que sa passerelle
Journalisation centralisée dans la zone d'administration	Un attaquant qui compromet une zone exposée ne peut pas effacer ses traces

Machine	Rôle	Adresse
FW-SIEGE	Pare-feu du siège, passerelle VPN	`203.0.113.2` (WAN) et `.1` de chaque zone
FW-SITE2	Pare-feu du site secondaire	`203.0.113.3` (WAN), `10.2.40.1` (LAN)
SRV-DMZ	Reverse proxy avec WAF, serveur web du portail	`10.1.10.10`, `10.1.10.20`
SRV-DEMO	Copie du portail avec données fictives	`10.1.20.10`
SRV-LDAP	Annuaire, base de données, services CRM et support simulés	`10.1.30.10`, `.20`, `.30`, `.50`
SRV-LOGS	Serveur de journalisation	`10.1.99.20`
CLIENT-TEST	Patient, médecin, employé distant ou attaquant sur Internet	`203.0.113.100`

3. Plan d'adressage

Principe	Justification
Plage privée `10.0.0.0/8`	Non routée sur Internet ; évite `192.168.0.0/16`, utilisé par presque toutes les box domestiques, ce qui créerait des conflits pour les télétravailleurs

Principe	Justification
Structure `10.<site>.<zone>.0/24`	Une adresse indique immédiatement le site (1 siège, 2 site secondaire, 8 VPN) et la zone
Un sous-réseau par zone, par service et par groupe VPN	Le pare-feu peut appliquer une règle différente à chacun
LAN de chaque site regroupé en `/21`	Une seule règle peut viser tout le LAN d'un site
`.1` = passerelle, serveurs fixes à partir de `.10`	Lecture et dépannage simplifiés

Réseau	Siège	Site secondaire
DMZ	`10.1.10.0/24`	—
DEMO	`10.1.20.0/24`	—
SERVEURS	`10.1.30.0/24`	—
LAN-USERS (un VLAN par service, n° VLAN = 3e octet)	`10.1.40.0/21` (`10.1.41` à `10.1.46`)	`10.2.40.0/21`
ADMIN	`10.1.99.0/24`	`10.2.99.0/24`
Pools VPN par groupe	`10.8.10.0/24` support, `.20` comptabilité, `.30` employés, `.40` informaticiens, `.50` administrateurs, `.60` commerciaux	—
Tunnel entre sites	`10.255.0.0/30` (`.1` siège, `.2` site secondaire)	
WAN (Internet simulé)	`203.0.113.0/24`, plage réservée à la documentation	

4. Zones de sécurité et niveaux de confiance

Zone	Contenu	Confiance	Justification
INTERNET	Patients, médecins, attaquants	0	Aucune maîtrise
DMZ	Reverse proxy, serveur web	1	Exposée à Internet : isolée du réseau interne, aucun accès direct aux serveurs
DEMO	Copie du portail, données fictives	2	Isolée et jetable : aucun accès vers les autres zones
VPN-USERS	Utilisateurs distants, un pool par groupe	2 à 3	Réseaux d'origine non maîtrisés ; droits selon le groupe
LAN-USERS	Postes des employés, un VLAN par service	3	Cibles privilégiées (hameçonnage) : segmentés par service
SERVEURS	Annuaire, base de données, CRM, support	4	Données sensibles, jamais joignables depuis Internet
ADMIN	Administration, journalisation	5	Critique : séparée de tous les flux utilisateurs

Le niveau de confiance fixe le sens des flux : un flux d'une zone moins fiable vers une zone plus fiable est interdit, sauf ouverture ciblée. La base de données n'est pas en DMZ : un attaquant qui prend le contrôle du serveur web n'obtient pas pour autant les données.

5. VPN utilisés

5.1 VPN site-à-site (IPsec)

Choix	Justification
IKEv2	Version actuelle du protocole d'échange de clés, plus robuste qu'IKEv1
Mode route-based (interface virtuelle)	Le tunnel est une interface : le trafic qui en sort est filtré par des règles, comme une zone
Algorithmes négociés : AES-128, SHA-256, courbe ECP-256	Chiffrement, intégrité et confidentialité persistante

Choix	Justification
(IKE) ; AES-GCM-128 (données)	
WAN ouvert en UDP 500, UDP 4500 et ESP **depuis la seule adresse de l'autre pare-feu**	Un tiers sur Internet ne peut pas engager de négociation
Politiques IPsec désactivées	Seul le trafic routé vers le tunnel est chiffré ; avec les politiques actives, tout le trafic du pare-feu y partait, y compris l'administration

Le tunnel n'est pas une zone de confiance : seul le flux LAN du site secondaire → serveur support du siège (TCP 80) est autorisé, filtré à la sortie du site secondaire et à l'entrée du siège.

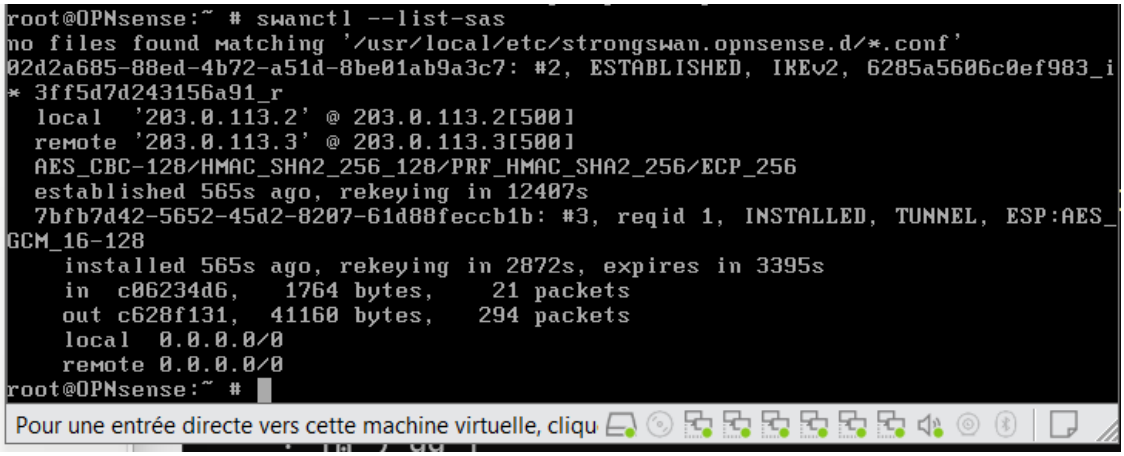


Figure 2 : tunnel établi (phase 1) et installé (phase 2)

5.2 VPN d'accès distant (OpenVPN)

Un serveur OpenVPN par groupe, chacun avec son port et son pool d'adresses (trois groupes mis en œuvre, les autres suivent le même modèle) :

Instance	Port UDP	Pool	Authentification
VPN-Support	1194	`10.8.10.0/24`	Annuaire, conteneur `ou=support`
VPN-Admin	1195	`10.8.50.0/24`	Annuaire, conteneur `ou=admins`
VPN-Commerciaux	1196	`10.8.60.0/24`	Annuaire, conteneur `ou=commerciaux`

- **Chiffrement AES-256-GCM**, sans algorithme de repli plus faible.
- **Clé `tls-crypt`** : tout paquet sans cette clé est ignoré sans réponse. Un balayage d'Internet ne révèle pas le VPN et ne permet pas de tenter des mots de passe, ce qui justifie l'ouverture des ports à toute adresse.
- **Certificat serveur** émis par une autorité dédiée au VPN ; le fichier de configuration distribué ne contient ni le certificat ni la clé du serveur, et interdit l'enregistrement du mot de passe.

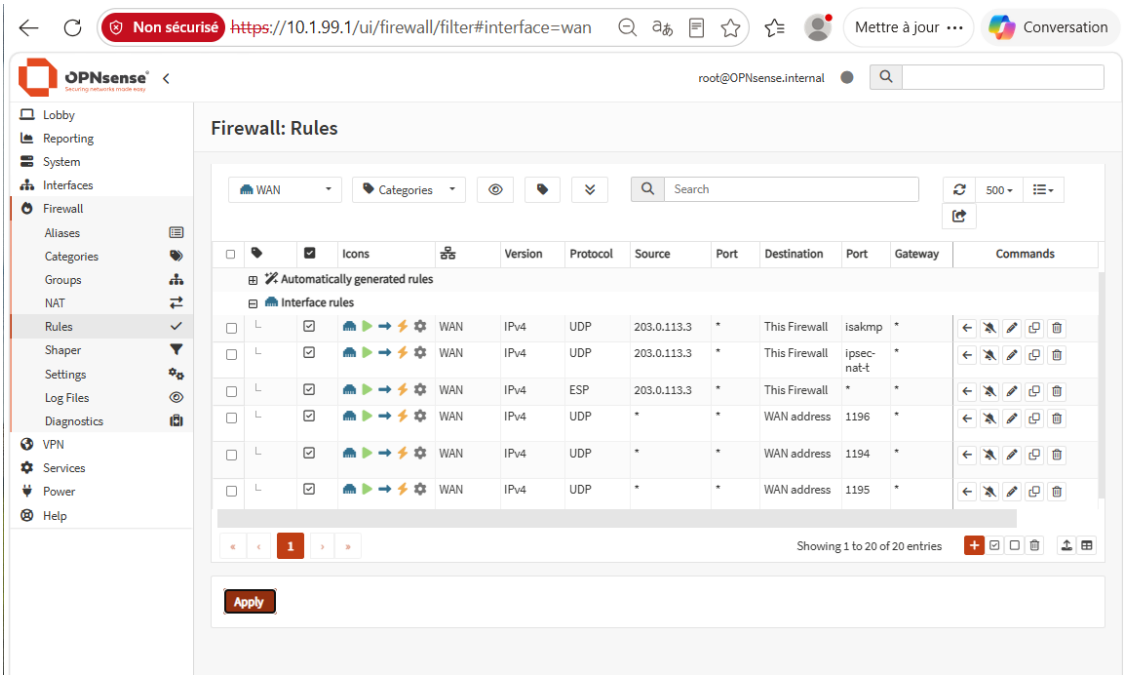


Figure 3 : un port par instance OpenVPN, ouvert sur le WAN

6. Mécanismes d'authentification

Qui	Mécanisme	Justification
Employés et commerciaux distants	Fichier de configuration (clé `tls-crypt`) + identifiant et mot de passe vérifiés dans l'annuaire, limité au groupe de l'instance	Un compte d'un autre service est refusé même avec un mot de passe correct
Médecins	Mot de passe + code à usage unique TOTP (RFC 6238)	Niveau de sécurité supérieur exigé par le sujet : un mot de passe volé ne suffit pas
Patients	Portail public, prise de rendez-vous sans compte	Les fonctions authentifiées des patients relèvent de l'application, hors périmètre
Pare-feu entre eux	Clé pré-partagée IPsec de 32 caractères aléatoires	Simple pour la maquette ; certificats recommandés en production
Applications entre elles	Pare-feu → annuaire : compte de service en lecture seule, en LDAPS ; portail → base : compte aux droits minimaux, `scram-sha-256`, connexion chiffrée	Moindre privilège pour les comptes techniques

L'annuaire (OpenLDAP) a été durci : lecture anonyme interdite (seul le compte de service du pare-feu peut lire les comptes), mots de passe stockés hachés, écoute **uniquement en LDAPS** (port 636, certificat d'une autorité propre au laboratoire) : un mot de passe vérifié par le pare-feu ne circule jamais en clair.

L'authentification des médecins comprend une phase d'enrôlement (QR code scanné par une application d'authentification, compte activé seulement après un premier code correct). Elle est protégée contre les attaques courantes : message identique pour un identifiant inconnu ou un mauvais mot de passe (pas de recherche des comptes existants), nouvelle session après chaque étape (pas de fixation de session), retour à la connexion après 5 codes faux, cookies `Secure`, `HttpOnly` et `SameSite=Strict`, expiration après 30 minutes. Les mots de passe ne sont stockés que sous forme d'empreinte (scrypt).

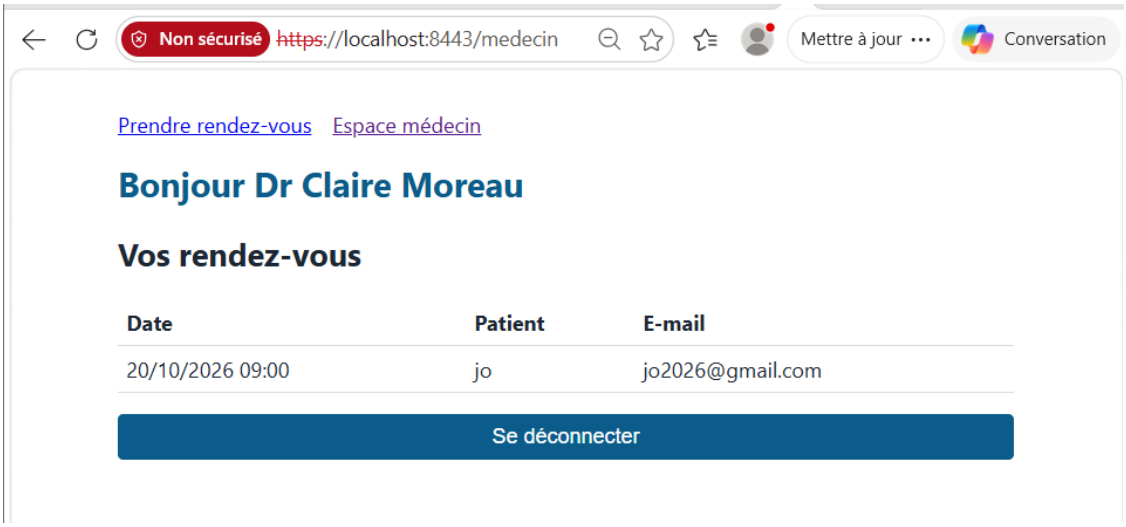


Figure 4 : espace médecin après authentification à deux facteurs

7. Politique de filtrage

Principes. Tout est interdit par défaut et chaque interface se termine par une règle de blocage **journalisée et nommée** (« DMZ : tout le reste interdit »…). Chaque flux autorisé précise source, destination, protocole et port. Les règles utilisent des **alias** (`H_DB`, `VPN_COMMERCIAUX`…) : elles se lisent sans connaître le plan d'adressage. Les règles « tout autoriser » et « anti-verrouillage » créées par défaut sur le LAN ont été supprimées.

Interface	Source	Destination	Port	Rôle
WAN	Toute adresse	Redirection vers le reverse proxy	TCP 443	Seul service public
WAN	Toute adresse	Pare-feu	UDP 1194–1196	VPN d'accès distant
WAN	`203.0.113.3` uniquement	Pare-feu	UDP 500, 4500, ESP	Tunnel entre sites
DMZ	Serveur web	Base de données	TCP 5432	Fonctionnement du portail
DMZ	DMZ	Serveur de journalisation	TCP 514	Seule exception DMZ → ADMIN
Chaque zone	La zone	Sa passerelle uniquement	DNS 53, NTP 123	Services d'infrastructure, sans sortie vers Internet
OpenVPN	Selon le groupe	Voir section 8		Règles d'identité
IPsec	LAN du site secondaire	Serveur support	TCP 80	Accès inter-sites
ADMIN	Poste d'administration	Pare-feu	HTTPS 443	Administration
Toutes	Tout	Tout	Tout	**Blocage journalisé**

Le pare-feu évalue les règles de haut en bas et s'arrête à la première qui correspond : le blocage final est toujours en dernière position. Les journaux montrent l'efficacité de cette politique : le serveur de la DMZ, qui tentait de joindre des serveurs de temps publics, est bloqué par la règle finale de sa zone.

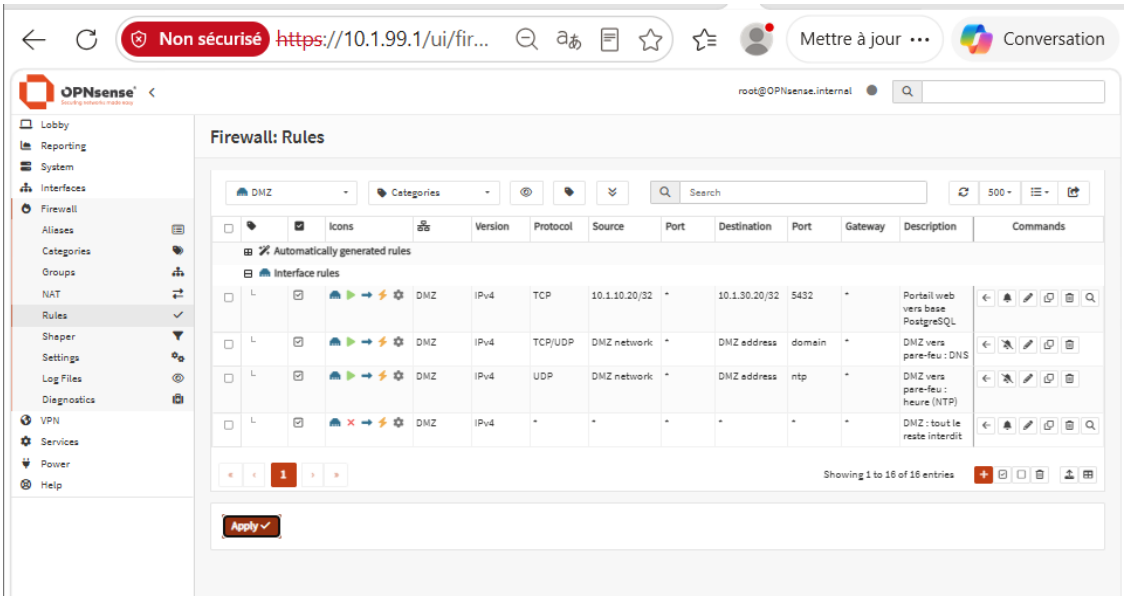


Figure 5 : règles de la DMZ, terminées par un blocage journalisé

8. Règles basées sur l'identité

Le pare-feu ne connaît pas directement l'utilisateur ; l'identité est traduite en adresse réseau :

1. l'annuaire range chaque compte dans le conteneur de son service ;
2. chaque serveur VPN n'accepte que les comptes de son conteneur ;
3. chaque serveur VPN attribue des adresses dans le pool de son groupe ;
4. les règles du pare-feu portent sur ces pools.

Groupe	Ressource autorisée	Port
Commerciaux (`VPN_COMMERCIAUX`)	CRM, portail DEMO	TCP 80, TCP 443
Support (`VPN_SUPPORT`)	Serveur support	TCP 80
Administrateurs (`VPN_ADMINS`)	Annuaire en SSH (temporaire, en attendant un bastion)	TCP 22
Tout autre flux	Bloqué et journalisé	

La démonstration est faite depuis le même poste Internet, avec une **route forcée** vers toute la zone SERVEURS : l'utilisateur contourne la configuration de son poste, et seul le pare-feu décide.

Utilisateur	CRM	Serveur support
Commerciale `c.durand`	**Autorisé** (`200 OK`)	**Bloqué**
Support `s.martin`	**Bloqué**	**Autorisé** (`200 OK`)

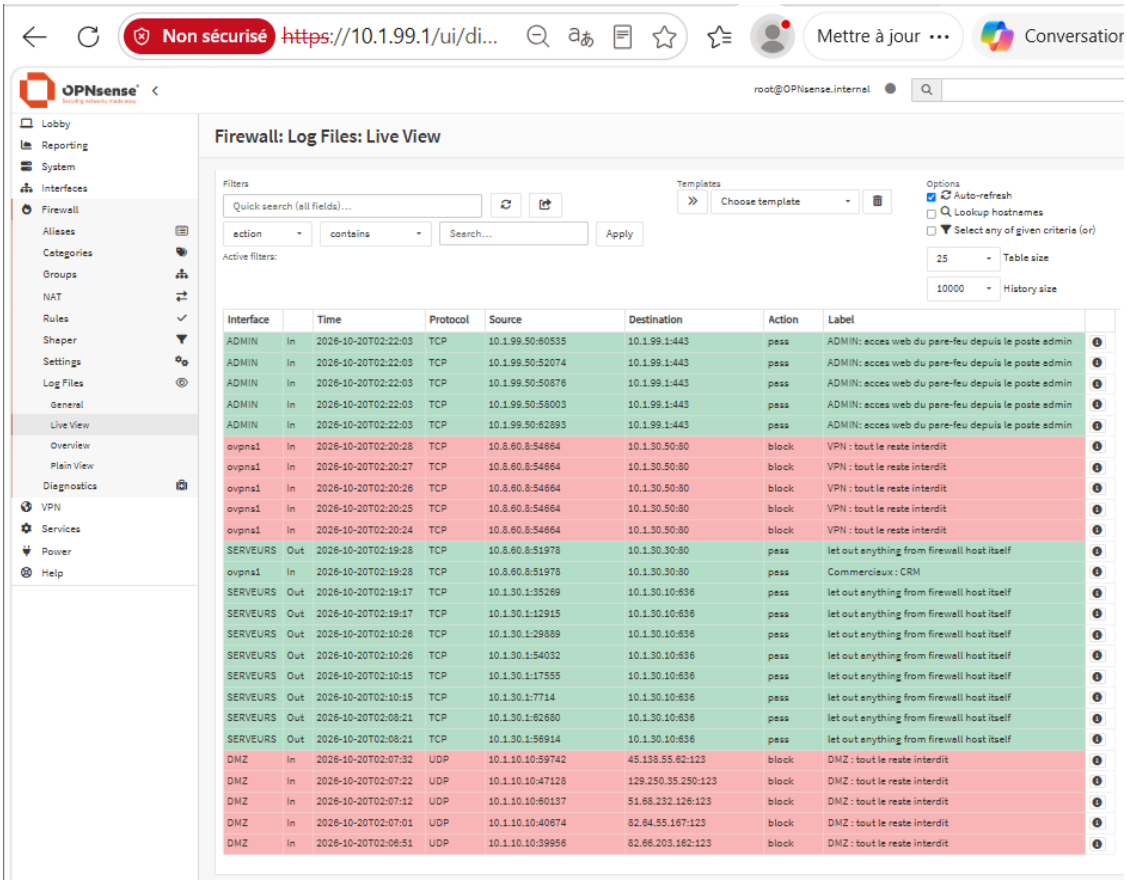


Figure 6 : pour la même utilisatrice, le pare-feu autorise le CRM (« Commerciaux : CRM ») et bloque le serveur support (« VPN : tout le reste interdit »)

9. Contrôle applicatif

Le filtrage par adresse et par port ne voit pas le contenu d'une connexion autorisée : une attaque envoyée sur le port 443 du portail passe une règle qui autorise ce port. Le trafic du portail étant chiffré, seul le reverse proxy, qui termine le HTTPS, voit les requêtes en clair : c'est là qu'est placé le contrôle applicatif du trafic web.

Élément	Choix
Moteur	ModSecurity 3 intégré au reverse proxy Nginx (pare-feu applicatif web, WAF)
Règles	OWASP Core Rule Set, 924 règles : injections SQL, scripts intersites, inclusion de fichiers, anomalies de protocole
Mode	Blocage : au-delà d'un score de suspicion, réponse `403 Forbidden`
Traçabilité	Motif de chaque blocage dans le journal d'audit, copié sur le serveur de journalisation

Une injection SQL (`?id=1' OR 1=1--`) est bloquée et journalisée (« SQL Injection Attack Detected via libinjection »), tandis que le parcours normal (rendez-vous, connexion d'un médecin avec son code) fonctionne sans faux positif. Le test a d'ailleurs montré l'intérêt de vérifier un blocage : le WAF « installé » ne chargeait d'abord que 7 règles de base, et l'injection passait.

Le contrôle applicatif des autres communications repose sur les règles d'identité (section 8), qui limitent chaque groupe à ses applications. Un IPS sur le pare-feu n'a pas pu être déployé (section 15).

```
root@srv-dmz:/etc/nginx# ls /etc/modsecurity/crs/
cat > /etc/nginx/modsecurity_includes.conf <<'EOF'
include modsecurity.conf
include /etc/modsecurity/crs/crs-setup.conf
include /usr/share/modsecurity-crs/rules/*.conf
EOF
nginx -t && systemctl restart nginx && grep "rules loaded" /var/log/nginx/er
ror.log | tail -1
echo "--- Requete normale :"
curl -sk -o /dev/null -w "%{http_code}\n" "https://10.1.10.10/"
echo "--- Injection SQL :"
curl -sk -o /dev/null -w "%{http_code}\n" "https://10.1.10.10/?id=1%27%20OR%
201=1--"
crs-setup.conf
REQUEST-900-EXCLUSION-RULES-BEFORE-CRS.conf
RESPONSE-999-EXCLUSION-RULES-AFTER-CRS.conf
2026/10/21 14:13:36 [notice] 4352#4352: ModSecurity-nginx v1.0.3 (rules load
ed inline/local/remote: 0/924/0)
nginx: the configuration file /etc/nginx/nginx.conf syntax is ok
nginx: configuration file /etc/nginx/nginx.conf test is successful
--- Requete normale :
200
--- Injection SQL :
403
root@srv-dmz:/etc/nginx#
```

Figure 7 : requête normale acceptée (`200`), injection SQL bloquée (`403`)

10. Protection de la DMZ

Couche	Mesure
Exposition	Un seul port public (TCP 443), redirigé vers le reverse proxy ; le port 80 n'est pas ouvert
Reverse proxy	Seul point d'entrée ; TLS 1.2 minimum ; en-têtes de sécurité (HSTS, CSP, `X-Frame-Options`, `nosniff`) ; version masquée ; limitation à 10 requêtes par minute et par adresse sur l'espace médecin ; requêtes limitées à 64 Ko
WAF	Section 9
Application	Écoute sur une adresse interne seulement ; compte système sans droits ; service durci (système de fichiers en lecture seule, pas d'élévation de privilèges) ; requêtes SQL paramétrées ; jetons anti-CSRF
Base de données	Hors de la DMZ (zone SERVEURS) ; une seule source autorisée (le serveur web, `/32`), connexion chiffrée, compte limité : lecture des médecins, ajout de rendez-vous, aucune suppression
Sorties de la DMZ	Seulement la base (TCP 5432), la journalisation (TCP 514) et la passerelle (DNS, NTP) ; tout le reste est bloqué et journalisé

Si le serveur web est compromis, l'attaquant ne peut ni joindre l'annuaire, ni administrer quoi que ce soit, ni effacer ses traces, ni supprimer des rendez-vous ou créer un faux médecin.

11. Séparation entre production et démonstration

La zone DEMO contient `SRV-DEMO`, copie du portail avec **sa propre base locale, remplie uniquement de données fictives**, **ses propres secrets** (régénérés après la copie) et un bandeau « Environnement de démonstration » sur chaque page. Sa carte réseau d'installation a été retirée.

Test depuis la zone DEMO	Résultat
Base de données, annuaire et portail de production	Bloqués tous les trois
Commerciale connectée au VPN → portail DEMO	Autorisée, page de démonstration affichée

Une erreur de manipulation ou une compromission pendant une démonstration n'expose donc aucune donnée réelle.

```
root@srv-dmz:/# hostname; ip -br a show ens32; ip -br a show ens33
srv-demo
ens32            UP             10.1.20.10/24
ens33            UP             192.168.49.134/24 fe80::4085:4dc1:82d9:a37a/
64
root@srv-dmz:/# ip route add default via 10.1.20.1
for cible in 10.1.30.20/5432 10.1.30.10/636 10.1.10.10/443; do timeout 5 bas
h -c "</dev/tcp/${cible%/*}/${cible#*/}" 2>/dev/null && echo "$cible : OUVER
T" || echo "$cible : BLOQUE"; done
10.1.30.20/5432 : BLOQUE
10.1.30.10/636 : BLOQUE
10.1.10.10/443 : BLOQUE
root@srv-dmz:/#
```

Figure 8 : la zone DEMO ne peut joindre aucune ressource de production

12. Sécurisation de l'administration

Mesure	Mise en œuvre
Réseau dédié	Zone ADMIN (`10.1.99.0/24`, et `10.2.99.0/24` au site secondaire), sans aucun utilisateur
Interface des pare-feu	Écoute uniquement sur l'interface d'administration, en HTTPS, depuis un seul poste autorisé
LAN sans droit d'administration	Règles par défaut du LAN supprimées : l'interface d'administration n'est plus joignable depuis le LAN
Administration à distance	Réservée au VPN des administrateurs, authentifié par l'annuaire
Secrets	Mots de passe distincts par équipement, secrets aléatoires dans des fichiers lisibles par le seul compte concerné, aucun secret dans le dépôt de code

Le bastion prévu (`10.1.99.10`) n'a pas été déployé : les serveurs ont été administrés par leur console et, pendant l'installation, en SSH (section 15).

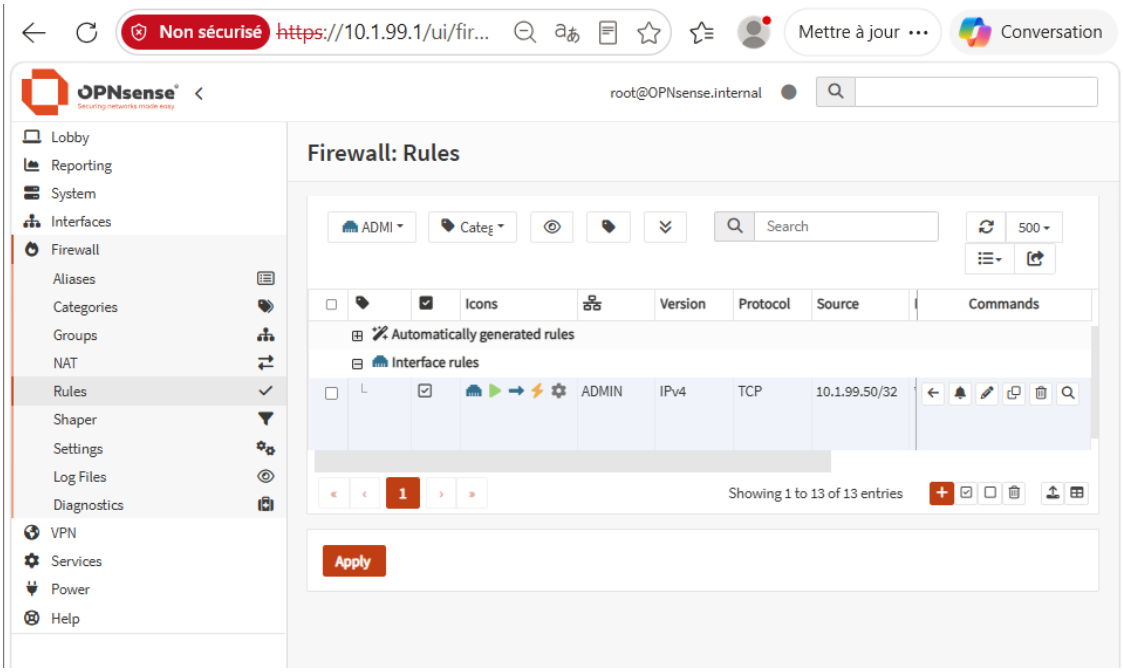


Figure 9 : seul le poste d'administration accède à l'interface du pare-feu

13. Stratégie de journalisation

Ce qui est journalisé : chaque blocage (avec le nom de la règle) et chaque passage par une règle sensible sur le pare-feu ; les connexions VPN ; les événements de sécurité du portail (échec de mot de passe, échec de code avec le numéro d'essai, activation du second facteur, connexion réussie, avec l'adresse source) ; les blocages du WAF. Les flux très fréquents et sans enjeu (DNS, heure) ne le sont pas, pour garder les journaux lisibles.

Choix	Justification
Copie en temps réel vers `SRV-LOGS` (zone ADMIN), un fichier par machine	Un attaquant qui compromet une zone exposée ne peut pas effacer la copie de ses traces
Envoi en TCP avec file d'attente sur disque depuis la DMZ	Aucune perte si le serveur de journalisation est momentanément injoignable
Format RFC 5424 depuis le pare-feu	Chaque ligne porte son fuseau horaire
Conservation de 52 semaines, compressée	Analyse possible d'un incident découvert tardivement
Heure commune (NTP) : le pare-feu du siège sert de référence ; chaque zone interroge sa passerelle ; le site secondaire se synchronise à travers le tunnel	Les journaux de plusieurs machines ne sont comparables qu'à la même heure ; l'authentification TOTP et les certificats en dépendent aussi

L'importance de l'heure a été vérifiée à nos dépens : un serveur avec deux heures d'avance refusait tous les codes TOTP, et un pare-feu en retard rejetait un certificat « pas encore valide ».

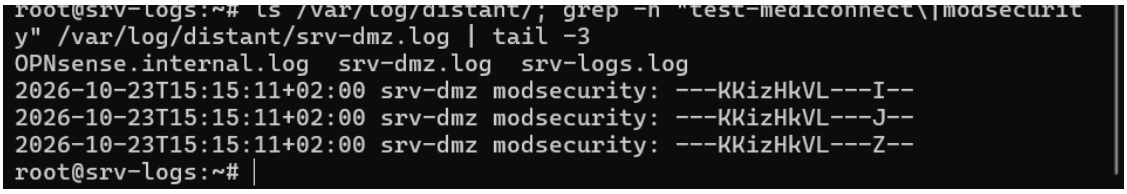


Figure 10 : blocage du WAF reçu sur le serveur de journalisation

14. Tests réalisés

Un blocage n'est retenu comme preuve que si le paquet atteint réellement le pare-feu (route forcée lors des tests VPN) ; chaque décision est confirmée par les journaux.

Objectif	Test	Résultat
Interconnexion des sites	Tunnel IKEv2	Établi, identifiants de session croisés
	Site secondaire → serveur support / → annuaire	Autorisé / bloqué
Accès distant	Compte du support sur le VPN des commerciaux	Refusé (`AUTH_FAILED`)
Identité	Commerciale → CRM / → support	Autorisé / bloqué
	Support → support / → CRM	Autorisé / bloqué
	Commerciale → annuaire en SSH (route forcée) / administrateur → annuaire en SSH	Bloqué / autorisé
Accès des patients	HTTPS depuis Internet ; prise de rendez-vous	`200 OK` ; enregistré
Accès des médecins	Mot de passe + code TOTP	Accès accordé
	Mauvais mot de passe ; 5 codes faux	Refus neutre ; retour à la connexion ; journalisés
Exposition du portail	Injection SQL ; usage normal avec WAF	`403` ; aucun faux positif
	Connexion serveur web → base	Acceptée et chiffrée
Production / démonstration	DEMO → production ; commerciale → DEMO	Bloqué (×3) ; autorisé
Administration	Accès web depuis le poste d'administration ; ping vers le pare-feu	Autorisé ; bloqué
Journalisation	Journaux du pare-feu et du WAF sur le	Reçus, un fichier par machine

Objectif	Test	Résultat
	serveur central	
	Envoi depuis la DMZ sans règle d'autorisation	Bloqué, visible dans les journaux

Difficultés instructives. Plusieurs « pannes » étaient le pare-feu qui faisait son travail : le serveur web sortait avec la mauvaise adresse vers la base ; une règle d'autorisation était placée après le blocage ; un conteneur d'annuaire mal saisi refusait un compte valide. À chaque fois, la correction a porté sur la machine ou l'ordre des règles, jamais sur un assouplissement du filtrage. Les journaux, qui nomment la règle responsable, ont permis chaque diagnostic.

15. Limites de la solution

Limite	Mesure en production
Pas d'IPS sur le pare-feu (pas d'accès Internet pour télécharger les signatures) : le contrôle applicatif ne couvre que le trafic web du portail	IPS Suricata en mode blocage sur les interfaces internes
Pas de bastion d'administration ; pare-feu administrés avec le compte `root`	Bastion seul autorisé en SSH, comptes nominatifs, enregistrement des sessions
Pas de second facteur pour le VPN ni pour l'administration	Code TOTP au minimum pour les administrateurs
VLAN par service non réalisés ; trois groupes VPN sur six	VLAN prévus par le plan d'adressage, authentification des postes 802.1X
Clé pré-partagée IPsec, clé `tls-crypt` commune, certificats auto-signés ou de laboratoire	Certificats pour IPsec, une clé par instance, certificat public pour le portail, autorité interne hors ligne
Verrouillage après 5 codes faux par session et non par compte ; secret TOTP non chiffré	Verrouillage temporaire du compte, secret chiffré, codes de secours
Journaux centralisés pour deux sources, sans analyse automatique, transport non chiffré	Toutes les machines, syslog sur TLS, outil de corrélation et d'alerte (SIEM)
Aucune redondance (un pare-feu, un annuaire, un tunnel) ; rôles regroupés sur une même machine	Haute disponibilité, annuaire répliqué, une machine par rôle
Heure de référence locale ; Internet simulé ; tunnel non relancé automatiquement après redémarrage	Serveurs de temps publics, vrais accès Internet, supervision du tunnel

16. Conclusion

La maquette répond aux objectifs du sujet : deux sites reliés par un tunnel chiffré, des accès distants dont les droits dépendent de l'identité dans l'annuaire, un portail exposé uniquement en HTTPS derrière un reverse proxy et un pare-feu applicatif, des médecins authentifiés par deux facteurs, une zone de démonstration incapable d'atteindre la production, une administration isolée et une journalisation centralisée.

Les tests le montrent : deux utilisatrices connectées au même pare-feu par le même type de VPN obtiennent des droits différents, une attaque cachée dans un flux autorisé est bloquée, et chaque refus apparaît dans les journaux avec le nom de la règle responsable. Le projet a aussi montré qu'un détail comme l'heure conditionne l'authentification, les certificats et l'exploitation des journaux.

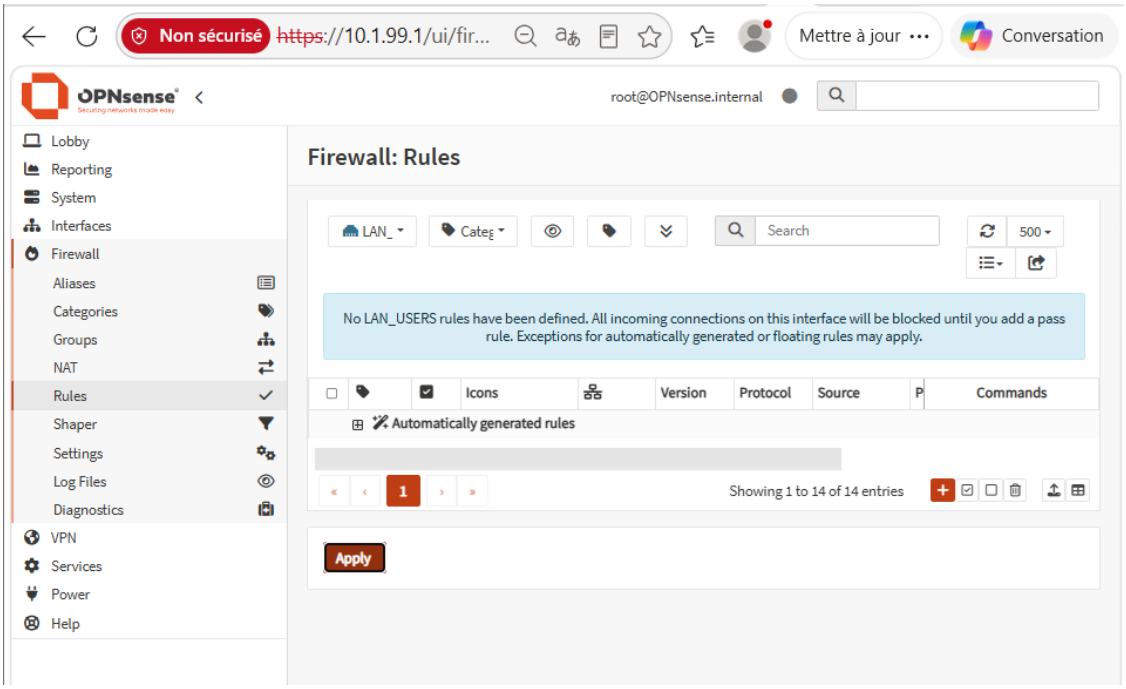
Les priorités pour une mise en production seraient un IPS sur le pare-feu, un bastion d'administration, des VLAN par service, un second facteur pour les administrateurs et la redondance des équipements critiques.

Annexe : captures complémentaires

Mise en place et intégrité

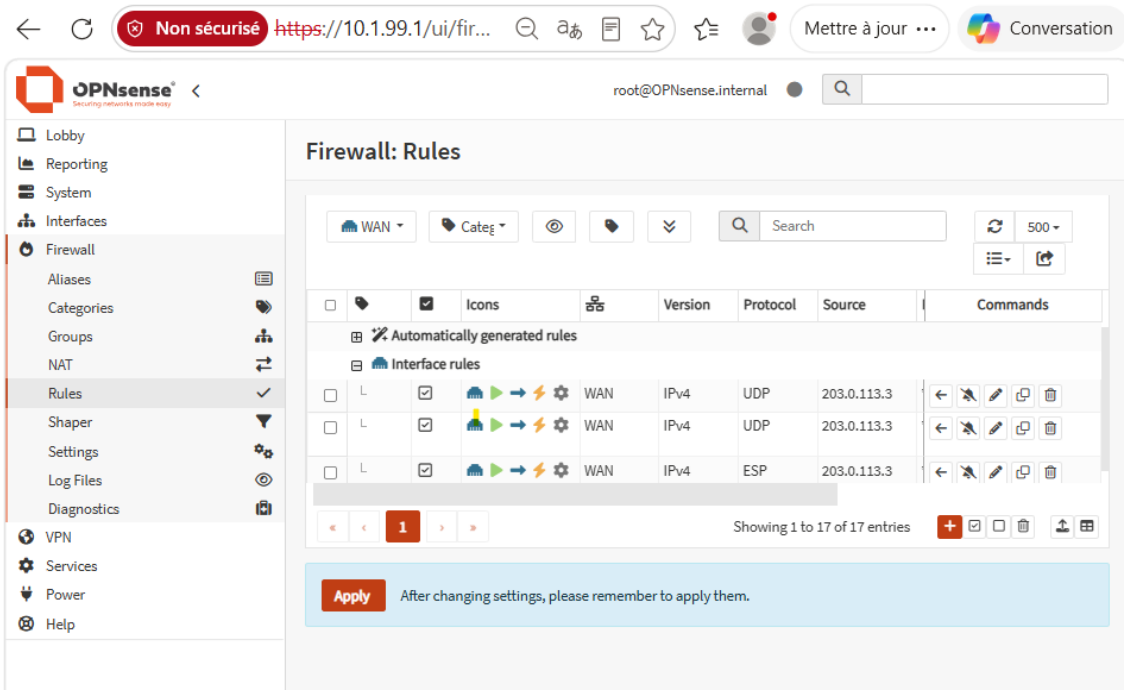
```
PS C:\Users\PC-PRET\Documents\mediconnect-network-security> $officiel = "95c
afedda6d5b22ce832e249dc2309110fbee19f813ad78cf28bb3d387186bfb"
PS C:\Users\PC-PRET\Documents\mediconnect-network-security> (Get-FileHash C:
\Labs\ISO\OPNsense-26.7-dvd-amd64.iso.bz2 -Algorithm SHA256).Hash -eq $offic
iel.Trim()
True
PS C:\Users\PC-PRET\Documents\mediconnect-network-security>
```

A1 : empreinte de l'image OPNsense comparée à celle publiée par l'éditeur



A2 : règles par défaut du LAN supprimées

VPN site-à-site

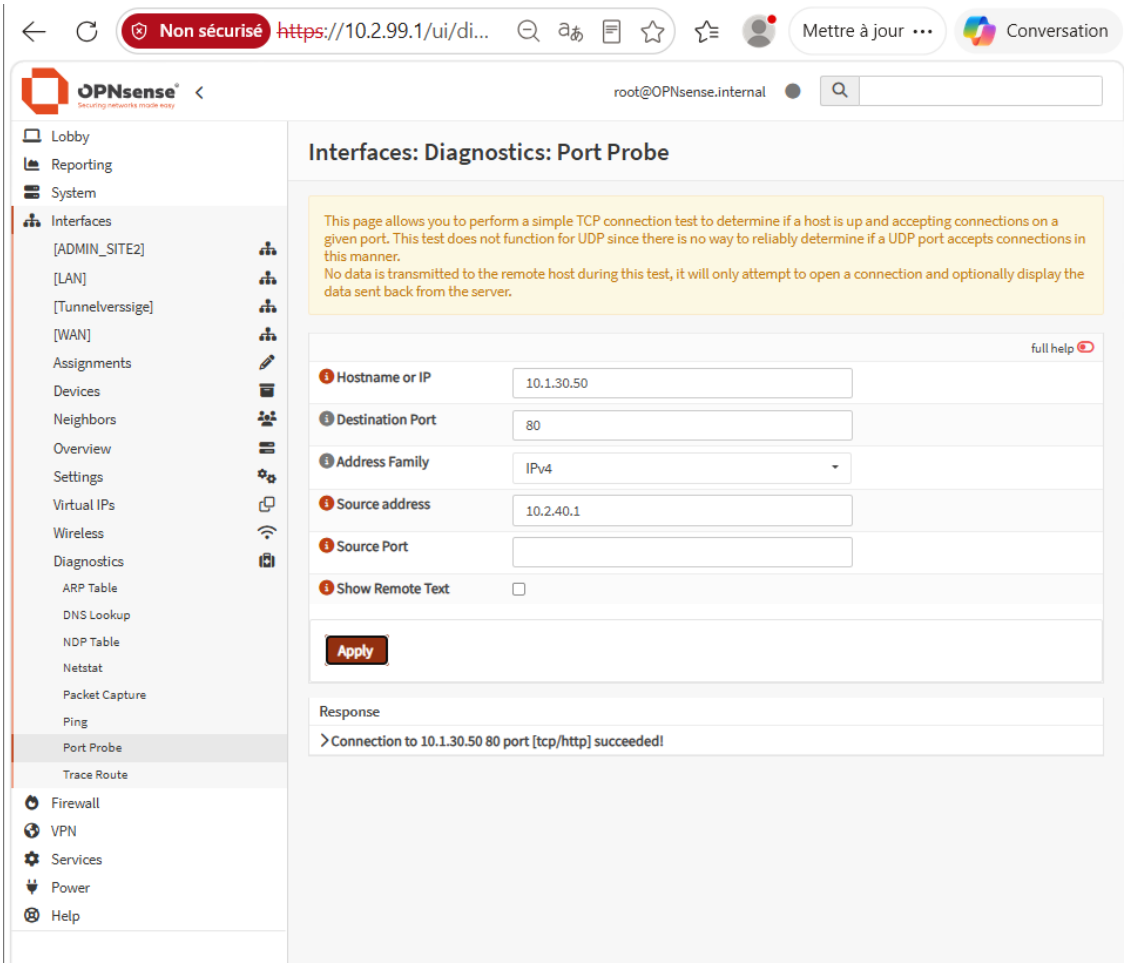


A3 : IPsec autorisé depuis la seule adresse du site secondaire

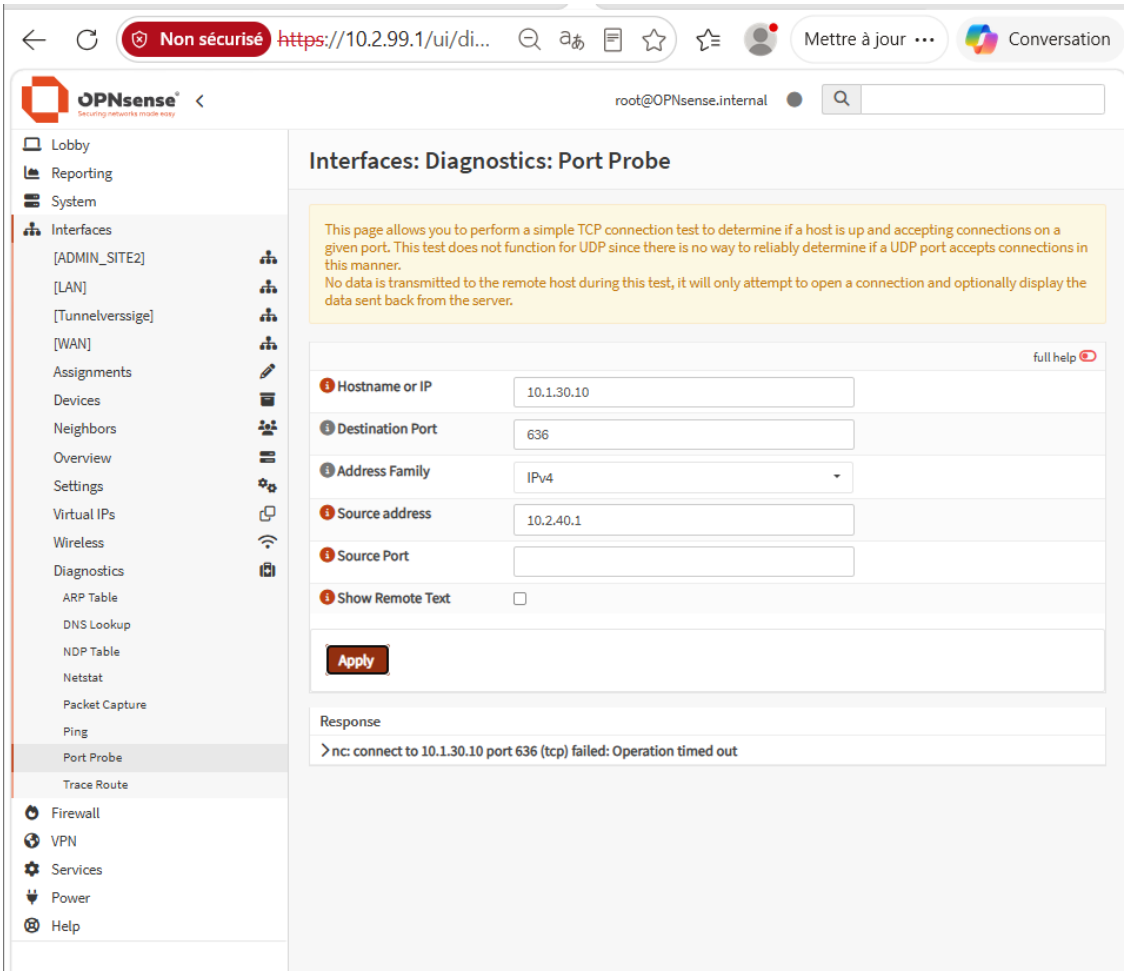
```
root@OPNsense:~ # ping -c 3 10.255.0.2
PING 10.255.0.2 (10.255.0.2): 56 data bytes
64 bytes from 10.255.0.2: icmp_seq=0 ttl=64 time=1.680 ms
64 bytes from 10.255.0.2: icmp_seq=1 ttl=64 time=2.698 ms
64 bytes from 10.255.0.2: icmp_seq=2 ttl=64 time=2.110 ms

--- 10.255.0.2 ping statistics ---
3 packets transmitted, 3 packets received, 0.0% packet loss
round-trip min/avg/max/stddev = 1.680/2.163/2.698/0.417 ms
root@OPNsense:~ #
```

A4 : trafic à travers le tunnel chiffré



A5 : le site secondaire atteint le serveur support du siège



A6 : l'annuaire reste inaccessible depuis le site secondaire

Annuaire et VPN d'accès distant

```
root@srv-ldap:~# ldapmodify -Y EXTERNAL -H ldapi:/// -f /root/acl.ldif
SASL/EXTERNAL authentication started
SASL username: gidNumber=0+uidNumber=0,cn=peercred,cn=external,cn=auth
SASL SSF: 0
modifying entry "olcDatabase={1}mdb,cn=config"

root@srv-ldap:~# ldapsearch -x -LLL -b ou=people,dc=mediconnect,dc=local dn
No such object (32)
root@srv-ldap:~# ldapsearch -x -D cn=opnsense-bind,ou=services,dc=mediconnec
t,dc=local -W -LLL -b ou=people,dc=mediconnect,dc=local dn
Enter LDAP Password:
dn: ou=people,dc=mediconnect,dc=local

dn: ou=admins,ou=people,dc=mediconnect,dc=local

dn: ou=support,ou=people,dc=mediconnect,dc=local

dn: ou=commerciaux,ou=people,dc=mediconnect,dc=local

dn: uid=a.bernard,ou=admins,ou=people,dc=mediconnect,dc=local

dn: uid=s.martin,ou=support,ou=people,dc=mediconnect,dc=local

dn: uid=c.durand,ou=commerciaux,ou=people,dc=mediconnect,dc=local

root@srv-ldap:~#
```

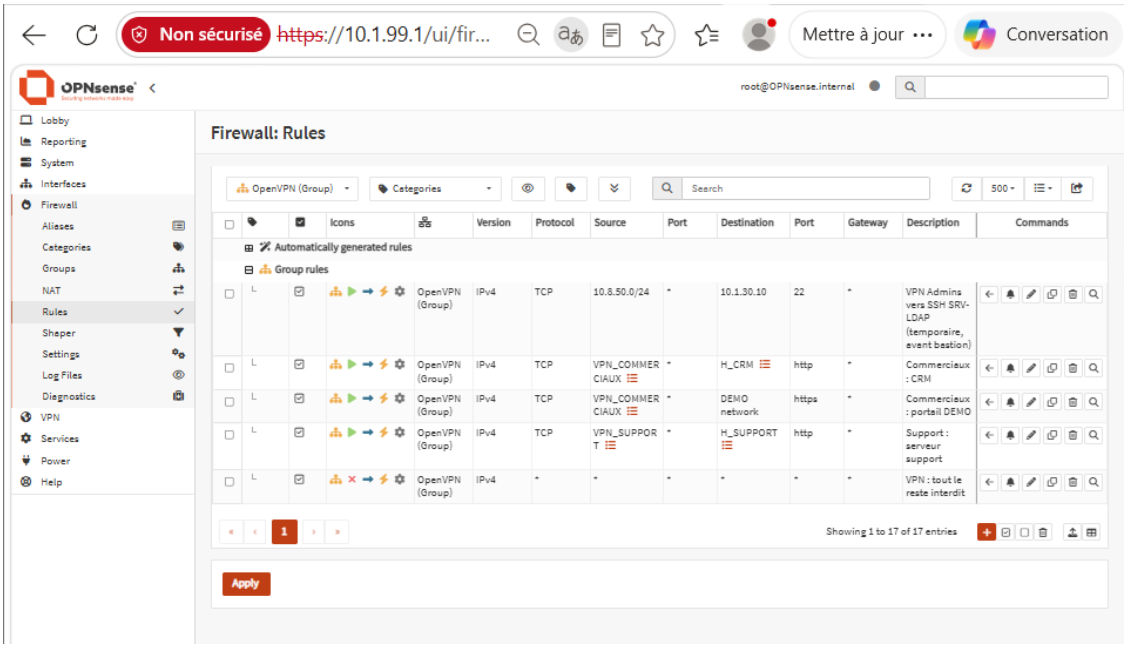
A7 : lecture anonyme de l'annuaire refusée

```
root@srv-ldap:/etc/ldap/tls# sed -i 's|^SLAPD_SERVICES=.*|SLAPD_SERVICES="ld
aps:/// ldapi:///"|' /etc/default/slapd
systemctl restart slapd
ss -tlnp | grep slapd
LISTEN 0      2048         0.0.0.0:636       0.0.0.0:*    users:(("slapd",pi
d=1302,fd=7))
LISTEN 0      2048            [::]:636          [::]:*    users:(("slapd",pi
d=1302,fd=8))
root@srv-ldap:/etc/ldap/tls# LDAPTLS_CACERT=/etc/ldap/tls/ca.crt ldapwhoami
-x -H ldaps://srv-ldap.mediconnect.local -D uid=c.durand,ou=commerciaux,ou=p
eople,dc=mediconnect,dc=local -W
Enter LDAP Password:
dn:uid=c.durand,ou=commerciaux,ou=people,dc=mediconnect,dc=local
root@srv-ldap:/etc/ldap/tls#
```

A8 : annuaire accessible uniquement en LDAPS

```
Enter Auth Username: s.martin
Enter Auth Password: ••••••••
2026-10-16 17:15:17 TCP/UDP: Preserving recently used remote address: [AF_INET]203.0.113.2:1196
2026-10-16 17:15:17 UDPv4 link local (bound): [AF_INET][undef]:0
2026-10-16 17:15:17 UDPv4 link remote: [AF_INET]203.0.113.2:1196
2026-10-16 17:15:17 [vpn.mediconnect.local] Peer Connection Initiated with [AF_INET]203.0.113.2:1196
2026-10-16 17:15:19 AUTH: Received control message: AUTH_FAILED
2026-10-16 17:15:19 SIGTERM[soft,auth-failure] received, process exiting
root@client-test:~#
```

A9 : connexion VPN refusée pour un compte d'un autre service



A10 : règles basées sur l'identité

```
root@client-test:~# wget -T 5 -t 1 http://10.1.30.30/
--2026-10-21 13:39:27--  http://10.1.30.30/
Connexion à 10.1.30.30:80… connecté.
requête HTTP transmise, en attente de la réponse… 200 OK
Taille : 51 [text/html]
Sauvegarde en : « index.html »

index.html                          100%[=================================================================================>]

2026-10-21 13:39:27 (1,93 MB/s) — « index.html » sauvegardé [51/51]

root@client-test:~# wget -T 5 -t 1 http://10.1.30.50/
--2026-10-21 13:39:49--  http://10.1.30.50/
Connexion à 10.1.30.50:80… échec : Le réseau n'est pas accessible.
root@client-test:~# ip route replace 10.1.30.0/24 dev tun0
root@client-test:~# wget -T 5 -t 1 http://10.1.30.50/
--2026-10-21 13:40:24--  http://10.1.30.50/
Connexion à 10.1.30.50:80… échec : Connexion terminée par expiration du délai d'attente.
Abandon.

root@client-test:~# _
```

A11 : la commerciale atteint le CRM, pas le serveur support

```
root@client-test:~# ip route replace 10.1.30.0/24 dev tun0
root@client-test:~# wget -T 5 -t 1 http://10.1.30.50/
--2026-10-21 13:58:38--  http://10.1.30.50/
Connexion à 10.1.30.50:80… connecté.
requête HTTP transmise, en attente de la réponse… 200 OK
Taille : 55 [text/html]
Sauvegarde en : « index.html.1 »

index.html.1                        100%[===================================================================================>]

2026-10-21 13:58:38 (2,17 MB/s) – « index.html.1 » sauvegardé [55/55]

root@client-test:~# wget -T 5 -t 1 http://10.1.30.30/
--2026-10-21 13:58:44--  http://10.1.30.30/
Connexion à 10.1.30.30:80… échec : Connexion terminée par expiration du délai d'attente.
Abandon.

root@client-test:~#
```

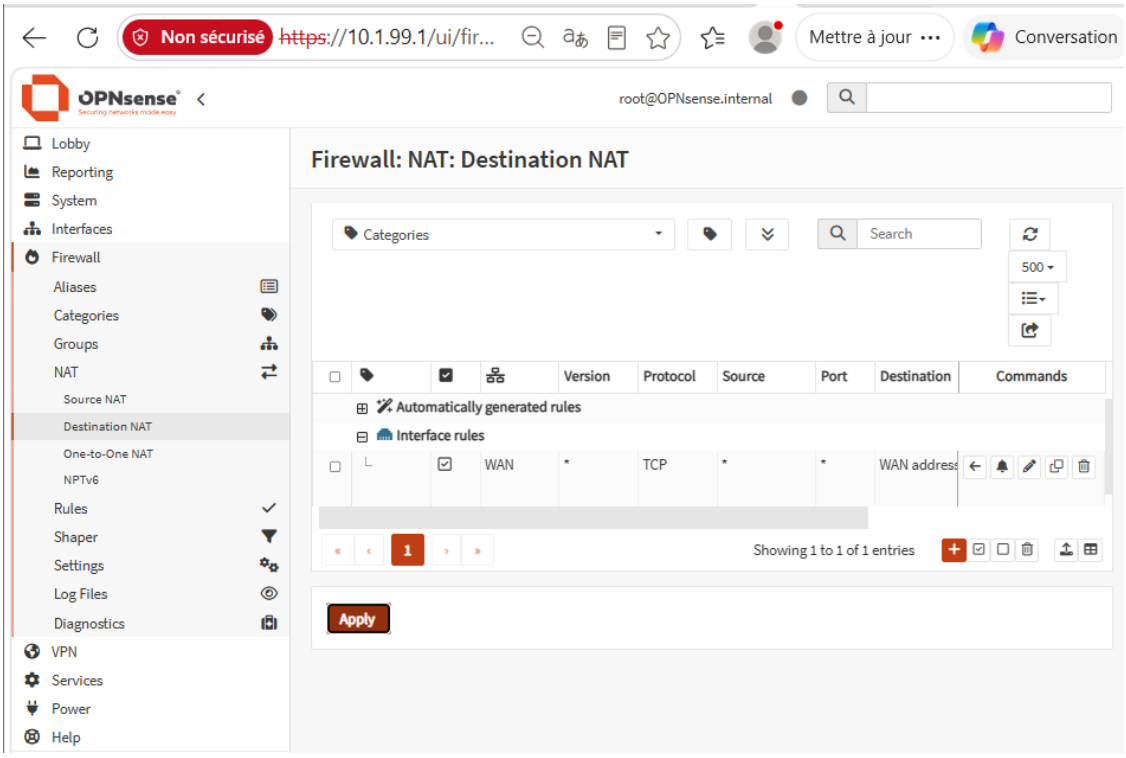
A12 : le support atteint son serveur, pas le CRM

Portail et DMZ

```
nginx: configuration file /etc/nginx/nginx.conf test is successful
LISTEN 0      511        10.1.10.10:443       0.0.0.0:*    users:(("nginx",pi
d=3003,fd=5),("nginx",pid=3002,fd=5))
HTTP/1.1 200 OK
Server: nginx
Date: Mon, 19 Oct 2026 20:59:53 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 1548
Connection: keep-alive
Vary: Cookie
Set-Cookie: session=eyJfY3NyZiI6InhLb2VzX2RSWGF2dzVHRVgwc1FSdk5hMDYxejVTY0Zv
NTIyd2Z0UHlncEEifQ.ataEyQ.eZxWlt0jM-a-b9uzZtLcSNVVzTo; Secure; HttpOnly; Pat
h=/; SameSite=Strict
Strict-Transport-Security: max-age=31536000
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Referrer-Policy: no-referrer
Content-Security-Policy: default-src 'self'; style-src 'unsafe-inline'; img-
src 'self' data:

root@srv-dmz:/opt/portail#
```

A13 : reverse proxy et en-têtes de sécurité



A14 : redirection du seul port 443 vers le reverse proxy

```
root@srv-dmz:~# PW=$(cat /tmp/dbpw) && sed -i "s|portail_app:[^@]*@|portail_
app:$PW@|" /etc/portail.env && shred -u /tmp/dbpw && unset PW
root@srv-dmz:~# set -a; . /etc/portail.env; set +a
root@srv-dmz:~# psql "$DATABASE_URL" -c "SELECT current_user, ssl FROM pg_st
at_ssl WHERE pid = pg_backend_pid();"
 current_user | ssl
--------------+-----
 portail_app  | t
(1 ligne)

root@srv-dmz:~#
```

A15 : connexion chiffrée du serveur web à la base de données

```
root@srv-dmz:~# journalctl -u portail -n 8 --no-pager | grep -i securite
oct. 21 13:26:19 srv-dmz gunicorn[3527]: [2026-10-21 13:26:19,650] WARNING i
n app: securite echec_totp ip=10.1.10.10 medecin=1 essai=2
oct. 21 13:26:43 srv-dmz gunicorn[3333]: [2026-10-21 13:26:43,891] WARNING i
n app: securite echec_totp ip=10.1.10.10 medecin=1 essai=3
oct. 21 13:27:42 srv-dmz gunicorn[3527]: [2026-10-21 13:27:42,021] WARNING i
n app: securite echec_totp ip=10.1.10.10 medecin=1 essai=4
oct. 21 13:27:47 srv-dmz gunicorn[3527]: [2026-10-21 13:27:47,465] WARNING i
n app: securite echec_totp ip=10.1.10.10 medecin=1 essai=5
oct. 21 13:28:09 srv-dmz gunicorn[3527]: [2026-10-21 13:28:09,669] WARNING i
n app: securite echec_totp ip=10.1.10.10 medecin=1 essai=1
oct. 21 11:30:14 srv-dmz gunicorn[3527]: [2026-10-21 11:30:14,532] WARNING i
n app: securite totp_active ip=10.1.10.10 medecin=1
oct. 21 11:31:04 srv-dmz gunicorn[3333]: [2026-10-21 11:31:04,918] WARNING i
n app: securite connexion_reussie ip=10.1.10.10 medecin=1
oct. 21 11:35:08 srv-dmz gunicorn[3527]: [2026-10-21 11:35:08,690] WARNING i
n app: securite echec_mot_de_passe ip=10.1.10.10 login=c.moreau
root@srv-dmz:~#
```

A16 : événements de sécurité du portail

```
root@srv-dmz:/etc/nginx# grep -o 'msg "[^"]*"' /var/log/nginx/modsec_audit.l
og | tail -5
msg "Host header is a numeric IP address"
msg "Host header is a numeric IP address"
msg "SQL Injection Attack Detected via libinjection"
msg "Inbound Anomaly Score Exceeded (Total Score: 8)"
root@srv-dmz:/etc/nginx#
```

A17 : motif d'un blocage du WAF

Démonstration, administration et journalisation

```
root@client-test:~# ip route replace 10.1.20.0/24 dev tun0
root@client-test:~# wget --no-check-certificate -T 5 -t 1 https://10.1.20.10/
--2026-10-23 13:58:22--  https://10.1.20.10/
Connexion à 10.1.20.10:443… connecté.
Avertissement : le certificat de « 10.1.20.10 » n'est pas de confiance.
Avertissement : le certificat de « 10.1.20.10 » n'est pas d'un émetteur connu.
requête HTTP transmise, en attente de la réponse… 200 OK
Taille : 1666 (1,6K) [text/html]
Sauvegarde en : « index.html.2 »

index.html.2                        100%[=================================================================================

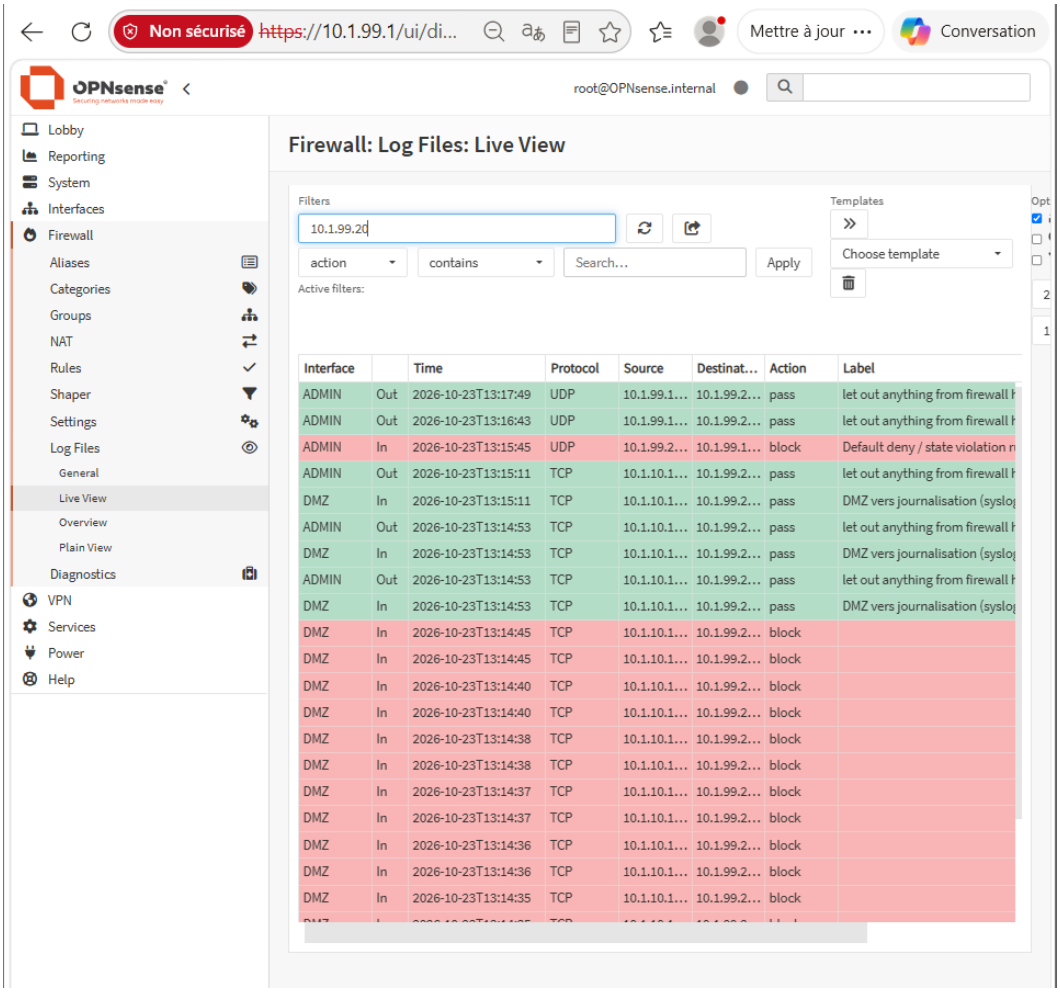
2026-10-23 13:58:22 (46,6 MB/s) — « index.html.2 » sauvegardé [1666/1666]

root@client-test:~# grep -o "ENVIRONNEMENT[^"<]" INDEX.HTML*
> ^C
root@client-test:~# grep -o "ENVIRONNEMENT[^"<]" index.html*
> ^C
root@client-test:~# grep -o DEMONSTRATION index.html.2
DEMONSTRATION
root@client-test:~#
```

A18 : accès de la commerciale au portail de démonstration

```
root@srv-logs:~# sleep 20; ls -l /var/log/distant/; tail -5 /var/log/distant
/OPNsense*.log
total 12
-rw-r--r-- 1 root root 5423 23 oct.  14:48 OPNsense.internal.log
-rw-r--r-- 1 root root   77 23 oct.  14:41 srv-logs.log
2026-10-23T12:48:00+02:00 OPNsense.internal openvpn_server2[57051]: MANAGEME
NT: CMD 'status 3'
2026-10-23T12:48:00+02:00 OPNsense.internal openvpn_server2[57051]: MANAGEME
NT: Client disconnected
2026-10-23T12:48:00+02:00 OPNsense.internal openvpn_server3[81010]: MANAGEME
NT: Client connected from /var/etc/openvpn/instance-f51b7758-361d-4488-af82-
e4053ac5e97b.sock
2026-10-23T12:48:00+02:00 OPNsense.internal openvpn_server3[81010]: MANAGEME
NT: CMD 'status 3'
2026-10-23T12:48:00+02:00 OPNsense.internal openvpn_server3[81010]: MANAGEME
NT: Client disconnected
root@srv-logs:~#
```

A19 : journaux du pare-feu sur le serveur central



A20 : envoi des journaux de la DMZ bloqué puis autorisé par sa règle

```
root@srv-dmz:~# mkdir -p /etc/systemd/timesyncd.conf.d && printf '[Time]\nNT
P=10.1.10.1\n' > /etc/systemd/timesyncd.conf.d/mediconnect.conf && systemctl
 restart systemd-timesyncd && sleep 10 && timedatectl timesync-status
       Server: 10.1.10.1 (10.1.10.1)
Poll interval: 1min 4s (min: 32s; max 34min 8s)
 Packet count: 0
root@srv-dmz:~#
```

A21 : serveur synchronisé sur sa passerelle